Chapter 2 – Cloud Security Threats and Risk Management

2.1 Common Cloud Threats

Cloud services host data and applications on remote servers managed by cloud service providers (CSPs) such as AWS, Microsoft Azure, and Google Cloud.- When these systems are misconfigured or poorly protected, attackers can exploit them, leading to serious security incidents.- Three high-impact threats in cloud environments are **data breaches, insecure APIs, and account hijacking**.

2.1.1 Data Breaches

Definition
A data breach occurs when confidential or sensitive information is accessed, viewed, stolen, or shared by people who are not authorized to see it.- In cloud computing this data is stored on CSP infrastructure, so any weakness at the CSP or customer side can lead to exposure.

Main Causes in Cloud Environments

Weak passwords: Simple or reused passwords can be guessed or cracked, giving attackers direct access to cloud accounts.

Poor access control: If an organization has not clearly defined "who can access what," users may see data far beyond their job needs.

Misconfigured cloud storage: Buckets or containers accidentally set to "public" instead of "private" can expose all stored data to the internet.

Phishing attacks: Fake emails or messages pretending to be from the CSP trick users into revealing their login credentials.

Software vulnerabilities: Unpatched applications or outdated services allow attackers to exploit known bugs to gain entry.

Examples

A 2019 incident where a major bank's customer data was exposed because an employee's access was misused.

Numerous cases where organizations stored credit card or medical data in open cloud storage buckets that anyone could access.

Impacts of Data Breaches

Financial loss: Fines, compensation to customers, and incident response costs.

Reputation damage: Customers lose trust in organizations that cannot protect their data.

Legal problems: Violations of data protection laws can lead to regulatory investigations and penalties.

Operational disruption: Systems may need to be shut down or isolated during investigation and recovery.

Prevention Measures

Enforce strong passwords and multi-factor authentication (MFA).

Encrypt data in transit and at rest.

Regularly update and patch all software and services.

Carefully configure storage access policies (no unnecessary public access).

Conduct periodic security audits and continuous monitoring.

Chandan Lohar

Provide user awareness training on phishing and safe handling of data.

2.1.2 Insecure APIs (Application Programming Interfaces)

Role of APIs in the Cloud
APIs enable communication between users, applications, and cloud services and are central to automation, integration, and management of cloud resources.- If APIs are not designed or secured properly, they become convenient entry points for attackers.

Why APIs Become Insecure

Lack of authentication: Some APIs do not strictly verify the identity of clients calling them.

Poor input validation: APIs that accept unvalidated input may allow injection of malicious code or commands.

Inadequate encryption: Data sent via APIs without encryption can be intercepted and read.

Excessive information disclosure: APIs that reveal detailed system or error information help attackers map the environment and plan attacks.

Typical Exploits

Stealing personal data from mobile apps via weakly protected back-end APIs.

Accessing customer databases through APIs that do not enforce proper authentication checks.

Abusing APIs to bypass restrictions and obtain administrative control of cloud systems.

Impacts

Unauthorized data access through API calls.

Service disruption via denial-of-service (DoS) using high-volume requests.

Data manipulation: Attackers can alter, delete, or inject false data.

Loss of trust when customers learn that their data was exposed through insecure integrations.

Best Practices for Securing APIs

Implement strong authentication and fine-grained authorization on all APIs.

Use HTTPS/TLS for all API communication.

Regularly test APIs with security tools (e.g., vulnerability scanning, penetration testing).

Apply rate limiting and throttling to prevent abuse and DoS.

Log and monitor API activity to identify unusual patterns early.

Keep API documentation private or access-controlled to avoid leaking internal details.

2.1.3 Account Hijacking

Definition
Account hijacking means an attacker gains control of a legitimate user's cloud account and can perform the same actions as that user, including viewing, modifying, or deleting data.

Methods Used by Attackers

Phishing: Tricking users into revealing usernames and passwords via fake emails or websites.

Password reuse: Using credentials leaked from one service to log into another where the user reused the same password.

Weak or stolen credentials: Guessable passwords and credentials exposed in breaches.

Chandan Lohar

Unsecured devices: Public or malware-infected systems capturing login details.

Session hijacking: Intercepting active authenticated sessions to take over accounts.

Consequences

Data theft or loss: Stealing or deleting critical information.

Unauthorized activities: Uploading malware, changing configurations, or misusing cloud resources.

Service disruption: Using hijacked accounts to attack others or disable services.

Financial loss: For example, using cloud compute instances for cryptocurrency mining.

Reputational damage: Customers lose confidence if their accounts are repeatedly hijacked.

Prevention

Use strong, unique passwords for every account and enforce MFA.

Avoid clicking suspicious links or opening attachments from unknown senders.

Review account activity logs regularly for unfamiliar logins or actions.

Educate users on phishing and social engineering tactics.

Use endpoint protection and ensure devices used for cloud access are secure.

2.2 Risk Management in Cloud Environments

Adopting cloud services requires a risk-based approach to security because organizations lose direct physical control over infrastructure and rely partly on the CSP.- Effective risk management ensures security, regulatory compliance, and business continuity.

2.2.1 Understanding Cloud Risks

Shared Responsibility Model
In the cloud, responsibility is divided between the CSP and the customer depending on the service model (IaaS, PaaS, SaaS).

CSP: Secures "security of the cloud" (data centers, networks, hardware).

Customer: Secures "security in the cloud" (data, OS, applications, access control, configurations).

Key Categories of Cloud Risks

Data Security and Privacy: Unauthorized access, data breaches, data leakage, and issues of data location/residency.

Compliance and Legal Risks: Failure to comply with regulations like GDPR, HIPAA, PCI-DSS, and unclear SLAs about incident response.

Governance and Control: Reduced visibility into CSP operations, shadow IT (unapproved cloud use), and weak IAM.

Vendor Lock-in and Exit Strategy: Difficulty and cost of migrating away from a single CSP; risk of downtime or data loss during exit.

Technical Vulnerabilities: Insecure configurations, weak encryption, and attacks on shared multi-tenant infrastructure.

Operational Risks: CSP outages, poor disaster recovery planning, and reliance on CSP patching/maintenance.

2.2.2 Risk Management Process

Chandan Lohar

Cloud risk management typically follows a cycle: **Identify → Assess → Mitigate → Monitor**.

1. Risk Identification

Goal: Discover all threats and vulnerabilities specific to the cloud deployment.

Key activities:

Cloud asset inventory: List all cloud assets – data, applications, VMs, containers, serverless functions.

Threat modeling: Analyze architecture to identify attack vectors (e.g., misconfigured S3 bucket exposing data).

Contract/SLA review: Carefully read Cloud Service Agreements to clarify responsibilities and identify gaps in the shared responsibility model.

Use of CSPM tools: Cloud Security Posture Management tools continuously scan configurations and detect risky setups like publicly accessible storage.

2. Risk Assessment

After identification, evaluate risks in terms of **likelihood** and **impact**.

Approaches:

Qualitative analysis: Assign High/Medium/Low ratings based on expert judgment; useful for quick prioritization.

Quantitative analysis: Estimate financial impact (e.g., Annualized Loss Expectancy – ALE) for more precise business justification.

Prioritization: Focus on high-impact, high-likelihood risks first (for example, a likely phishing attack on admin credentials is critical compared to a low-impact minor bug).

3. Risk Mitigation and Treatment Options

Risk treatment options in the cloud:

Avoidance: Do not use a particular cloud service or keep highly sensitive workloads on-premises.

Transfer/Sharing: Purchase cyber insurance or rely on CSP liability as defined in SLAs.

Acceptance: Document and accept low-level risks where mitigation cost is higher than potential loss.

Mitigation (Reduction): Implement technical and organizational controls to reduce likelihood or impact.

Key mitigation techniques:

Strong IAM (PoLP, MFA for admins).

CSPM for continuous configuration checking against benchmarks like CIS.

Network security (micro-segmentation, security groups, NACLs).

Encryption of data at rest and in transit.

Incident response planning with clear detection, containment, and recovery steps.

Use of security tools: firewalls, IDS/IPS, CASB, DLP, etc.

DevSecOps: integrating security scans and checks directly into CI/CD pipelines before deployment.

4. Risk Monitoring and Review

Because cloud environments change frequently (new services, changed roles, configuration updates), risk management must be continuous.

Activities:

Chandan Lohar

Continuous auditing of logs, configuration changes, and compliance status using automated tools (CSPM, CASB).

Regular testing of incident response plans, including coordination with the CSP for major outages or breaches.

Periodic reassessment of risks whenever new services are adopted, architectures are changed, or laws are updated.

Risk acceptance and transfer decisions are revisited to ensure they remain within the organization's risk appetite.

2.3 Identity and Access Management (IAM) Best Practices

IAM is the set of policies, processes, and tools used to manage digital identities and control who can access which resources.- It supports authentication, authorization, and auditing, and is critical to reduce insider threats and credential-based attacks.

Key best practices:

Understand IAM's Role

Verify user identity (authentication).

Decide what each user can do (authorization).

Maintain logs of activity (auditing).

Use Strong Authentication Methods

Complement passwords with MFA/2FA, using combinations of something you know (password), something you have (phone/smart card), and something you are (biometrics).

This greatly reduces account takeover risk if a password is compromised.

Follow Principle of Least Privilege (PoLP)

Give users only the minimum rights required for their job (e.g., HR should not access financial databases).

Review permissions regularly to remove unnecessary or outdated access.

Implement Role-Based Access Control (RBAC)

Assign permissions to roles like "Accountant" or "IT Administrator," then assign users to roles instead of managing each user separately.

This simplifies administration and ensures consistent enforcement of policies.

Apply Strong Password Policies

Enforce minimum length (e.g., 12 characters), complexity, and regular rotation.

Train users not to reuse passwords across multiple systems.

Automate User Provisioning and Deprovisioning

Automatically grant appropriate access when employees join or change roles and revoke access when they leave.

This reduces human error and closes security gaps due to orphaned accounts.

Regularly Review and Audit Access Rights

Perform periodic access reviews to detect inactive accounts, excessive privileges, or policy violations.

Use audit trails to investigate incidents and prove compliance.

Use Centralized IAM Systems and SSO

Chandan Lohar

Central platforms provide unified authentication, authorization, and monitoring.

Single Sign-On (SSO) improves usability and reduces risky password behavior.

Secure Privileged Accounts

Admin and root accounts should have stronger controls: mandatory MFA, frequent password changes, and separate accounts for admin vs normal work.

Use PAM tools to monitor and control privileged sessions.

Monitor and Log User Activities

Record "who accessed what, when, from where" and analyze logs for anomalies like repeated login failures or logins from unusual locations.

Educate and Train Employees

Regular awareness training on phishing, password hygiene, and incident reporting because human error is a major cause of breaches.

Adopt Zero Trust Architecture for IAM

Assume no user or device is trusted by default; continuously verify identity and device health.

Use network segmentation to limit lateral movement if an attacker enters the environment.

Ensure Compliance through IAM

Use IAM to enforce access controls demanded by regulations such as GDPR, HIPAA, and ISO 27001, and maintain detailed audit records.

Integrate IAM with Cloud and Hybrid Environments

Extend IAM to cloud platforms using providers like Azure AD, AWS IAM, Google Cloud Identity, and federated identity standards (SAML, OAuth).

Continuously Update IAM Policies

Regularly revise IAM strategies in response to new threats, technologies, and business requirements and keep all IAM components patched.

2.4 Data Protection, Encryption, and Secure Storage in the Cloud

2.4.1 Data Protection in the Cloud

Data protection covers **privacy, availability, and integrity** of data stored in a third-party cloud infrastructure.- It is not limited to preventing unauthorized access but includes policies and technologies across the entire data lifecycle.

Key aspects:

Privacy: Only authorized users should see or use the data; governed by regulations like GDPR and HIPAA.

Availability: Data must be accessible when needed using redundancy and robust disaster recovery.

Integrity: Data must remain accurate and unaltered; checksums and digital signatures help verify this.

Data governance and compliance: Policies for classification, retention, and deletion of data to meet legal requirements.

The **Shared Responsibility Model** again applies: CSP secures infrastructure, but the customer is responsible for securing their own data, applications, and configurations inside the cloud.

2.4.2 Encryption – Cornerstone of Cloud Security

Chandan Lohar

Encryption converts readable data into ciphertext so that unauthorized users cannot understand it. In the cloud it is applied at three stages:

Encryption in transit: Protects data while moving over networks (e.g., browser to cloud) using TLS/SSL; users see "HTTPS" in the address bar.

Encryption at rest: Protects data stored on disks and storage volumes, typically using algorithms like AES-256.

Encryption in use: Allows computation on encrypted data without decrypting it (e.g., homomorphic encryption), which is still emerging and not widely used for general workloads.

Key Management
Encryption is only as strong as key management practices.

CSP-managed keys: Provider generates and manages keys – simpler but requires high trust in CSP.

Customer-managed keys (BYOK): Customer generates and controls keys, often via a dedicated Key Management System (KMS), giving maximum control for sensitive data.

2.4.3 Secure Data Storage in the Cloud

Secure storage operationalizes data protection and encryption.

Core practices:

Strong IAM and PoLP for storage resources; users who only need read access must not be allowed to delete or modify data.

MFA for access to critical storage resources.

Network security and isolation: Use Virtual Private Cloud (VPC), security groups, and firewalls so storage is not publicly accessible unless truly necessary.

Regular auditing and monitoring: Use activity logs (e.g., AWS CloudTrail, Azure Monitor) to track all access and changes, reviewing them for suspicious behavior.

Data backup and disaster recovery: Implement regular backups and test restoration procedures.

Immutable (WORM) storage: Configure some backups as write-once, read-many so they cannot be altered or deleted for a specified period, protecting against ransomware.

Geographic redundancy: Store backup copies in different regions to withstand regional disasters such as floods or major power outages.

2.4.4 Choosing the Right Storage Service

Different cloud storage types have different characteristics and security considerations.

Storage Type	Description	Typical Use Cases	Security Notes
Object Storage (e.g., **S3**, **Azure Blob**)	Stores unstructured data as objects in buckets; highly scalable.	Websites, backups, big data lakes.	Defaults may be private, but **misconfiguration** can easily make buckets **public**; **strict bucket policies** required.cyber-ch2.pdf
Block Storage (e.g., **EBS**,	Acts as disks for virtual machines.	OS disks, application data volumes.	Must be **encrypted** at volume level and protected by the **VM's OS security controls**.cyber-ch2.pdf

Chandan Lohar

Storage Type	Description	Typical Use Cases	Security Notes
Azure Disks)			
File Storage (e.g., **EFS**, **Azure Files**)	Shared storage using file protocols like **NFS/SMB**.	Shared drives, content repositories.	Access control is **complex** because it involves both **cloud IAM** and **traditional file permissions**.cyber-ch2.pdf

Securing data in the cloud is an ongoing process, not a one-time configuration.

2.5 Security Compliance and Regulatory Frameworks

Digital transformation has massively increased collection, storage, and sharing of data, raising concerns about privacy, security, and misuse.- To address these concerns, legal and standardization bodies have created frameworks like **GDPR, IT Act 2000, and ISO 27001**.

Security compliance means following these laws and standards to maintain confidentiality, integrity, and availability of data, protect personal information, reduce cyberattack risk, and build customer trust.

2.5.1 GDPR – General Data Protection Regulation (EU)

Scope and Purpose
GDPR is an EU law that gives individuals in the EU strong rights over their personal data and applies to any organization worldwide that processes EU residents' data.

Key concepts:

Personal data: Any information identifying a person (name, email, bank details, IP, medical data, social media posts).

Data subject: Person whose data is processed.

Data controller: Entity deciding why and how data is processed.

Data processor: Entity processing data on behalf of the controller (e.g., CSP).

Seven core principles:

Lawfulness, fairness, transparency.

Purpose limitation.

Data minimization.

Accuracy.

Storage limitation.

Integrity and confidentiality (security controls).

Accountability (ability to demonstrate compliance).

Other important requirements:

Valid consent: Must be freely given, specific, informed, and unambiguous.

Chandan Lohar

Data subject rights: Access, correction, objection, and "right to be forgotten" (erasure).

Breach notification: Report most breaches to authorities within 72 hours and to individuals if there is high risk.

Fines: Up to €20 million or 4% of global annual turnover, whichever is higher.

2.5.2 IT Act 2000 – India

The IT Act 2000 is India's primary law for cybercrime and electronic commerce and gives legal recognition to electronic records and digital signatures.

Security-related components:

Legal recognition of electronic transactions and digital signatures.

Digital signature certificates issued by licensed Certifying Authorities.

Important sections:

Section 43A: Compensation when a company fails to protect sensitive personal data and this negligence causes loss.

Section 66: Computer-related offences (hacking, unauthorized access, damage).

Section 72: Penalty for breach of confidentiality and privacy by individuals who misuse information accessed in their official capacity.

SPDI Rules 2011: Define Sensitive Personal Data or Information (SPDI) like passwords, financial and health data, and require privacy policies, consent, and "reasonable security practices."

Penalties mainly take the form of fines/compensation and imprisonment for defined offences.

2.5.3 ISO 27001 – Information Security Management System (ISMS)

ISO 27001 is an international standard (not a law) that describes how to build and maintain an Information Security Management System (ISMS).

ISMS objectives:

Protect confidentiality, integrity, and availability of information.

Manage people, processes, and technology in a systematic, risk-based way.

Ten mandatory clauses (4–10) follow Plan-Do-Check-Act:

Clause 4: Context of the organization – define scope and environment.

Clause 5: Leadership – management commitment, policies, roles.

Clause 6: Planning – risk assessment and treatment planning.

Clause 7: Support – resources, competence, awareness, documentation.

Clause 8: Operation – implement and operate security controls.

Clause 9: Performance evaluation – monitoring, measurement, internal audits.

Clause 10: Improvement – corrective actions and continual improvement.

Annex A lists detailed security controls (access control, crypto, physical security, etc.), from which organizations select those needed to address their identified risks.

2.5.4 Relationship Between Laws and Standards

GDPR and IT Act 2000 are **mandatory laws**, while ISO 27001 is a **voluntary standard**.- An organization can use ISO 27001's ISMS as evidence that it has implemented appropriate measures required by these laws (like "appropriate technical and organizational measures" in GDPR or "reasonable security practices" in the IT Act/SPDI Rules).

Chandan Lohar